

Báo cáo tuần 3

Lập dàn ý nghiên cứu chi tiết
WAF Log Analyzer

Nhóm G21 IT6027 lớp 26.1A01

25 tháng 9 năm 2026

Nguồn	solution-design v1.6, rule-creation v1.1, báo cáo tuần 2, metrics.md
Việc tuần này	Ba câu hỏi nghiên cứu, cấu trúc thí nghiệm, dàn ý nghiên cứu thử
Số liệu	Coverage và FPR offline đã đo . Replay $\geq 10\,000$ dòng là thiết kế

Tuần 1 chốt đề tài giám sát tấn công web từ access log: Nginx ghi JSON, Kafka chuyển log, rule engine tự viết chấm điểm 0–100, Alert gán một-một với sự kiện, Incident chỉ mở theo chính sách, SSE đẩy cho SOC. LLM có hai vai trò tách nhau: mine rule ngoài luồng, và giải thích Incident sau khi Incident đã tạo. Tuần 2 kết luận đề xuất nằm trong tài nguyên lab và không trùng đủ các hướng ML-WAF, sinh chữ ký WAF inline, SIEM thu log, hay LLM triage. Tuần 3 chuyển hai kết luận đó thành kế hoạch đo được, gồm mốc 15% trên đúng đại lượng mà thí nghiệm kiểm soát.

Đề án không hỏi regex có accuracy cao hơn SVM trên CSIC hay không. Đề án hỏi bộ 14 rule đã qua cổng FPR, cùng chính sách Incident, còn giữ coverage và còn giảm tải triage hay không khi dữ liệu từ khoảng 80 request lab thành luồng từ 10 000 dòng có mốc thời gian.

1. Mô tả: từ ý tưởng đã khoá sang việc phải đo

Ba quyết định đã chốt trong thiết kế, và mỗi quyết định sai theo một kiểu riêng. Dàn ý vì thế có ba câu hỏi, không gộp thành một câu “hệ thống có tốt không”.

Bảng 1: Ba quyết định và kiểu sai tương ứng.

Quyết định đã khoá	Kiểu sai	Câu hỏi
14 rule regex; LLM không detect	Coverage trên log sống tụt so với CSV tĩnh	RQ1
Alert khi $\text{score} \geq 60$; Incident khi CRITICAL hoặc đủ $K=3$	Giảm incident nhưng bỏ sót tấn công nặng, hoặc giảm chưa tới 15%	RQ2
Kafka, hạn request đến alert dưới 5 giây	Đúng trên tập lab nhỏ, vỡ khi replay lớn	RQ3

Cấu trúc nghiên cứu là thực nghiệm có đối chứng trên lab Compose. Baseline nội bộ là chính sách một alert một incident, và chính bộ coverage held-out đã ghi trong metrics.md. ModSecurity, WAFBooster và SVM không chạy lại trên lab này; chúng xuất hiện như mốc đối chiếu đã công bố.

2. Ba câu hỏi nghiên cứu

RQ1 — Coverage khi rời CSV tĩnh. Trên đúng 14 rule đã pass cổng evaluator ($\text{precision} \geq 0,80$ và $\text{FPR} \leq 0,02$), coverage ruleset theo category trên access log có mốc thời gian có lệch quá 15 điểm phần trăm so

với held-out tĩnh đã đo hay không? Mốc held-out: SQLI 50,52% trên 6 598 mẫu, XSS 68,12% trên 229 mẫu, PATH_TRAVERSAL 48,00% trên 175 mẫu. FPR trên phân benign của luồng phải $\leq 2\%$.

RQ2 — Tải triage và mốc 15%. Trên cùng một luồng log có nhãn, chính sách Incident có giảm số incident phải triage ít nhất 15% so với baseline một alert một incident hay không, trong khi mọi alert CRITICAL vẫn được gắn incident? Luật promote giữ nguyên thiết kế: IMMEDIATE khi severity CRITICAL (score ≥ 85); AGGREGATE khi đủ $K=3$ alert MEDIUM hoặc HIGH cùng khoá (app_id, client_ip) trong cửa sổ $W=5$ phút.

RQ3 — Thời gian thực trên dữ liệu lớn. Với ngưỡng alert mặc định 60, phân vị 95 của độ trễ từ request tới Nginx đến lúc alert xuất hiện trên GET /api/stream/alerts có nhỏ hơn 5 giây khi replay ít nhất 10 000 dòng, ở nhịp tối thiểu 20 sự kiện mỗi giây, hay không?

Mỗi câu có mẫu số, ngưỡng và baseline. Câu “phương pháp có hơn 15% trên dữ liệu lớn không” được trả ở mục 5; RQ2 là chỗ mốc 15% đi vào giả thuyết của đề án, vì đó là đại lượng chính sách Incident thực sự đổi được.

3. Cấu trúc nghiên cứu

3.1 Phương pháp

Một nhân tố đổi tại một thời điểm, trên cùng 14 rule, để hiệu ứng policy không bị trộn với hiệu ứng đổi rule.

Bảng 2: Nhân tố thí nghiệm.

Nhân tố	Mức baseline	Mức đề xuất
Việc SOC	1 alert = 1 incident	IMMEDIATE / AGGREGATE, $K=3$, $W=5$ phút
Quy mô	S: ~ 50 sạch + ~ 30 probe ≈ 80 request	L: replay $\geq 10\,000$ dòng JSON
Nhịp	Script probe	≥ 20 sự kiện/giây (≈ 500 giây cho 10 000 dòng)

Điểm của mỗi request giữ công thức đã chốt, vì các RQ đo hệ đó chứ không đổi trọng số giữa chừng:

$$\begin{aligned}
 \text{base} &= \min(100, \sum \text{weight}), \\
 \text{freq_bonus} &= \begin{cases} 0 & \text{nếu ít hơn 2 hit cùng IP trong 5 phút,} \\ \min(20, 2(\text{count} - 1)) & \text{ngược lại,} \end{cases} \\
 \text{status_bonus} &= 5 \text{ nếu status} \in \{403, 404, 500\} \text{ và base} > 0, \\
 \text{score} &= \min(100, \text{base} + \text{freq_bonus} + \text{status_bonus}).
 \end{aligned}$$

Alert tồn tại khi score ≥ 60 . Severity gợi ý: MEDIUM 40–69, HIGH 70–84, CRITICAL ≥ 85 . Hit có điểm dưới 60 không vào mẫu số RQ2.

Bảng 3: Chỉ số thu thập.

Chỉ số	Cách tính	Gắn RQ
Coverage category	Mẫu tấn công khớp ít nhất một rule của category, chia cho số mẫu category	RQ1
Precision, FPR	Công sẵn: precision $\geq 0,80$; FPR $\leq 0,02$	RQ1
Số alert, số incident	Đếm sau một lần chạy cố định	RQ2
Mức giảm incident	$(I_{\text{base}} - I_{\text{new}})/I_{\text{base}}$	RQ2
CRITICAL bỏ sót	Alert CRITICAL còn incident_id null	RQ2, kỳ vọng 0
p95 độ trễ	$t_{\text{SSE}} - t_{\text{request}}$ trên request có alert	RQ3

Đồng hồ RQ3 không gồm LLM. Profile llm tắt và explanation_status = SKIPPED. Trộn thời gian Ollama vào p95 sẽ đo một hệ khác với pipeline phát hiện.

3.2 Dữ liệu đã có và dữ liệu cần thu

Bảng 4: Các tầng dữ liệu và quy mô.

Tầng	Quy mô	Thời gian	Vai trò
HttpParams	19 304 norm + 11 763 anom = 31 067. Anom: SQLi 10 852, XSS 532, PT 290, cmdi 89	Không	Corpora và FPR. Cmdi không có trong 14 rule
Held-out	SQLi 6 598, XSS 229, PT 175. Tổng 7 002	Không	Mốc coverage RQ1
Adversarial	SQLi 32 851, XSS 1 111, PT 808. Tổng 34 770	Không	Biến thể encoding
CSIC 2010	~ 36 000 thường + ~ 25 000 bất thường ≈ 61 000	Không	Đối chiếu quy mô ML-WAF
Lab Juice	~ 50 sạch + ~ 30 probe ≈ 80	Có	Tầng S
Replay	≥ 10 000 dòng JSON	Gán khi sinh	Tầng L

So với khoảng 80 request lab, HttpParams lớn gấp khoảng 388 lần (31 067/80), riêng adversarial SQLi lớn gấp khoảng 1 095 lần so với 30 probe (32 851/30), và replay 10 000 dòng lớn gấp khoảng 125 lần. “Dữ liệu lớn” trong dàn ý này là mốc 10 000 dòng có timestamp.

HttpParams và CSIC không có event_time. Cửa sổ 5 phút chỉ chạy sau khi mỗi giá trị tham số được bọc thành một dòng access log: host, path, query, status, user_agent, raw, cộng event_time và client_ip theo kịch bản. Luồng L trộn 80% benign từ norm và 20% tấn công từ held-out, tức khoảng 8 000 dòng sạch và 2 000 dòng tấn công trên 10 000 dòng. POST body không thu. Tấn công chỉ nằm trong body là FN của kênh access log, đếm riêng, không cộng vào mẫu số coverage.

Bảng 5: Coverage ruleset đã đo trên 14 rule (precision từng rule = 1, FPR benign = 0).

Category	Held-out	Adversarial	FPR benign
PATH_TRAVERSAL	0,4800 trên 175	0,5136 trên 808	0,0000
SQLI	0,5052 trên 6 598	0,4958 trên 32 851	0,0000
XSS	0,6812 trên 229	0,6985 trên 1 111	0,0000

Coverage là hợp của các rule. Sáu rule SQLi trên held-out cho 530 + 256 + 63 + 509 + 1 099 + 1 146 = 3 603 hit thô, trong khi 50,52% của 6 598 là khoảng 3 333 mẫu phân biệt; phần chênh là pattern chồng nhau. PT-DOUBLE-001 có recall held-out 0/175 và chỉ 2/808 trên adversarial. Coverage PT 48% đến chủ yếu từ PT-DOTDOT-001 (84/175) và PT-BACKSLASH-001 (34/175). Báo cáo sau khi chạy phải nêu rule gần như không đóng góp.

4. Điều chỉnh phương pháp bài báo cho dữ liệu thời gian thực

Bốn hướng đối chiếu đo trên tập tĩnh hoặc trên WAF inline. Access log Kafka thêm bốn ràng buộc: chỉ có field của log, mỗi sự kiện phải xong nhanh, sự kiện có thứ tự thời gian, và đầu ra cho người trực là incident.

Năm bước điều chỉnh, theo thứ tự phụ thuộc:

1. Mine rule xong trước khi mở luồng. Evaluator đã chạy trên 7 002 mẫu held-out và 34 770 mẫu adversarial. Consumer chỉ nạp rule trong rules/production/.
2. Bọc chuỗi tĩnh thành log. Thiếu bước này thì RQ1 không có mẫu access log, và W=5 phút không có trực

Bảng 6: Phần giữ và phần đổi của từng hướng khi đưa sang luồng log.

Hướng gốc	Số đã công bố	Cách đưa vào lab realtime
WAFBooster [3]	True rejection 21% → 96% trên 8 WAF	Giữ ý cụm payload rồi rút regex và có đo false rejection. Bỏ shadow RNN, GPU, WAF đen. Runtime là 14 regex Java theo <code>target_field</code>
GenXSS [4]	15 SecRule chặn khoảng 86% bypass XSS	Giữ cụm rồi LLM viết rule, số rule cỡ mười lăm. Abstract rule trước compiler. Thêm SQLI và path traversal. Cổng precision 0,80, FPR 0,02. Không GPT-4o, không CRS
ML-WAF trên HttpParams và CSIC	Accuracy trên split tĩnh; CSIC khoảng 61 000 request	Giữ nhãn ba họ tấn công và dùng HttpParams. Detector trên Kafka là regex có <code>rule_id</code> . Cửa sổ tần suất 5 phút cần timestamp
SIEM Filebeat–Kafka	Pipeline thu log, alert thường một-một	Giữ Filebeat và hai topic. Normalize trong Spring, SSE, tách Alert và Incident, JWT role admin

thời gian để trượt.

3. Detect và chấm điểm trên đường xử lý sự kiện. SSE fan-out bất đồng bộ. LLM không gọi trong thí nghiệm độ trễ.
4. Khoá một bộ tham số: ngưỡng 60, cửa sổ tần suất 5 phút, $W=5$ phút, $K=3$. Đổi K sau khi nhìn số làm RQ2 mất baseline.
5. Rule cần POST body loại từ spec. FN của kênh nhìn ghi riêng, không đem so với bài báo được đọc full HTTP rồi kết luận “kém 15%”.

`freq_bonus` và `promote AGGREGATE` chỉ khác batch CSV khi nhiều hit cùng IP rơi vào 5 phút. Replay gán mỗi mẫu một IP, hoặc giãn thời gian quá cửa sổ, thì RQ2 ra mức giảm 0% dù code `promote` đúng. Kích bản IP ở mục 6.2 thuộc phương pháp đo.

5. Mốc 15% khi áp phương pháp bài báo lên dữ liệu lớn

Mức cải thiện các bài báo công bố đều lớn hơn 15%, nhưng đó là mức cải thiện lúc **vá chữ ký hoặc chặn bypass**, không phải mức cải thiện lúc **tăng kích thước dữ liệu**, và không chuyển sang luồng access log. Đề án không ghi 21% → 96% hay khoảng 86% vào cột kết quả kỳ vọng. Mốc 15% đặt vào giả thuyết Incident (RQ2) và vào sản tụi coverage khi đổi miền dữ liệu (RQ1).

Bảng 7: Hai cách đọc “hơn 15%” trên số của WAFBooster.

Cách đọc	Định nghĩa	Số true rejection 21% → 96%
Tuyệt đối	Tăng ≥ 15 điểm phần trăm	$96 - 21 = +75$ điểm. Vượt mốc
Tương đối	$(\text{sau} - \text{trước}) / \text{trước} \geq 0,15$	$(96 - 21) / 21 = 3,57$, tức +357% so với WAF gốc. Vượt mốc

Cả hai cách đọc mô tả cùng một thí nghiệm: thêm chữ ký cho WAF inline, đo trên payload đột biến, so với chính WAF đó lúc chưa vá, trên 8 sản phẩm. GenXSS báo khoảng 86% bypass XSS bị 15 SecRule chặn; bài không có cặp “tập nhỏ / tập lớn” của cùng một bộ rule. Ba câu dưới đây vẫn mở.

Tăng kích thước có làm phương pháp ấy tốt thêm từ 15% trở lên không? WAFBooster và GenXSS không công bố cặp đo ấy. Với chữ ký, thêm benign — HttpParams đã có 19 304 mẫu norm, CSIC khoảng 36 000 request thường — làm mẫu số FPR lớn hơn. Đại lượng cạnh tranh là FPR và số alert. Accuracy không tự tăng 15% vì file dài hơn.

Con số ấy còn nghĩa trên access log realtime không? True rejection là tỉ lệ payload bị WAF chặn. Coverage của đồ án là tỉ lệ mẫu trong log khớp rule. GenXSS chỉ XSS và nhìn request tới ModSecurity; đồ án có ba category và không thấy body. Shadow RNN và GPT-4o cũng không nằm trong ngân sách $p95 < 5$ giây của consumer. +75 điểm và khoảng 86% vì thế không vào bảng kết quả mong đợi của nghiên cứu thử.

Nội bộ đã có một phép thử “tập lớn hơn” chưa? Adversarial SQLi có 32 851 mẫu, khoảng 5,0 lần held-out 6 598. Coverage adversarial SQLi 49,58% lệch held-out 50,52% đúng 0,94 điểm. XSS: 69,85% so với 68,12%, lệch +1,73 điểm. PT: 51,36% so với 48,00%, lệch +3,36 điểm. Trên miền chuỗi tĩnh cùng kiểu biến thể, coverage đứng yên trong vài điểm, không nhảy +15 điểm. Replay 10 000 dòng kiểm tra tiếp khi chuỗi đó thành log có nhịp 20 sự kiện mỗi giây.

Bảng 8: Giả thuyết của đồ án và mốc không lấy từ bài báo.

Giả thuyết	Đạt khi	Không dùng làm tiêu chí
H1, RQ2	Incident giảm $\geq 15\%$ so với 1-1; CRITICAL bỏ sót = 0	True rejection 96%
H2, RQ1	SQLi $\geq 35,52\%$, XSS $\geq 53,12\%$, PT $\geq 33,00\%$; FPR $\leq 2\%$	Accuracy SVM trên CSIC
H3, RQ3	$p95 < 5$ giây tại ≥ 20 sự kiện/giây, trên $\geq 10\,000$ dòng	Thời gian sinh payload RNN hoặc GPT-4o

Sàn H2 trừ 15 điểm phần trăm vì coverage đã là phần trăm: $50,52 - 15 = 35,52$, $68,12 - 15 = 53,12$, $48,00 - 15 = 33,00$. Đọc tương đối 15% chặt hơn với SQLi: $50,52 \times 0,85 = 42,94\%$. Tiêu chí quyết định của dàn ý này là 15 điểm phần trăm; báo cáo kết quả sau nên ghi cả hai.

Hai biên làm H1 không đứng, dù code promote đúng. Chúng phải có trong báo cáo kết quả.

- 18 alert CRITICAL từ 18 IP, mỗi IP một request: baseline 18 incident, đề xuất 18 incident, mức giảm 0%. IMMEDIATE không gộp khác IP.
- 2 alert MEDIUM cùng IP trong 5 phút: baseline 2 incident, đề xuất 0 incident vì chưa đủ $K=3$. Mức giảm incident là 100%, và hai alert vẫn nằm trên feed. RQ2 đếm incident; số alert chưa promote phải đi kèm, nếu không 100% bị đọc thành “hết tấn công”.

6. Dàn ý nghiên cứu thử nghiệm

Lần thử rút gọn RQ1–RQ3 trong lab Compose hiện có. Mục tiêu của lần thử là có quy trình ra số, và biết H1 có đứng trên một kịch bản IP đã tính trước hay không. Lần thử không nhằm đẩy coverage lên tối đa.

6.1 Giới thiệu bối cảnh

SOC lab nhìn Juice Shop qua Nginx. Request sạch và probe thành JSON access log, Filebeat đẩy raw-web-logs, Spring chuẩn hoá thành WebEvent, chấm điểm, tạo Alert, rồi xét Incident. Lần thử lấy mốc SSE bằng curl -N; dashboard React không cần có mặt để chấm độ trễ.

Bối cảnh có ý lịch bốn hướng đối chiếu ở đúng chỗ phương pháp đo:

- So với ML-WAF, đầu ra là hit có rule_id, weight và evidence, rồi tới incident. HttpParams 31 067 giá trị vẫn dùng, ở vai corpora và benign.
- So với WAFBooster, lab không có 8 WAF và không có shadow model. Chỗ đứng tương ứng với true rejection, trong lab này, là coverage trên mẫu tấn công và FPR trên norm cùng khoảng 50 request sạch.
- So với GenXSS, 14 rule trải ba category và đã qua cổng, thay cho 15 SecRule chỉ XSS. XSS là họ mỏng nhất ở nguồn (532 mẫu anom so với 10 852 SQLi). Coverage XSS held-out 68,12% trên 229 mẫu không được đọc thành “XSS đã xong”.

- So với SIEM một alert một incident, nhiều probe MEDIUM cùng IP trong 5 phút phải ra ít incident hơn số alert. Đó là hiện tượng cần đo.

Lần thử giữ ràng buộc tuần 2: không ModSecurity làm detector, không GPU, không cloud LLM, không DVWA. Thêm các thành phần ấy thì $p95$ và FPR không còn so được với hạn 5 giây và công 2%.

6.2 Phương pháp đề xuất

Dùng 14 rule đang pass. $risk_threshold = 60$, $W = 5$ phút, $K = 3$. JWT admin chỉ để gọi API đếm.

Luồng S. Khoảng 50 request sạch và 30 probe SQLi, XSS, path traversal qua Host: `juice.lab.local`. Ghi nhận theo scenario. Đếm alert và incident ở hai chế độ, và lấy $p95$ trên tập nhỏ làm mốc máy lạnh.

Luồng L. 10 000 dòng JSON. 120 dòng đầu là kịch bản kiểm tra H1, mọi sự kiện tấn công của mỗi IP nằm trong một cửa sổ 5 phút. Phần còn lại là nền 80/20 để đo FPR và $p95$, không trộn vào bảng đếm 120 dòng.

Bảng 9: Kịch bản 120 request để chấm policy. Cột incident đề xuất giả định detector gán đúng severity.

IP	Request	Alert	Baseline	Đề xuất	Kiểu
10.0.0.8	6 CRITICAL	6	6	1	IMMEDIATE
10.0.0.9	9 MEDIUM	9	9	3	AGGREGATE
10.0.0.10	3 HIGH	3	3	1	AGGREGATE
10.0.0.11	40 sạch	0	0	0	—
IP sạch khác	62 sạch	0	0	0	—
Tổng	120	18	18	5	

Mức giảm thiết kế $(18 - 5)/18 = 13/18 = 72,2\%$, trên mốc 15%. Bảng này chấm code promote khi detect đúng severity. Nếu một probe đáng lẽ CRITICAL chỉ được MEDIUM, bảng thực đo đặt cạnh bảng này, không sửa bảng thiết kế cho khớp. Sáu CRITICAL cùng IP phải vào một incident mở sẵn: `alert_count = 6`, không mở incident thứ hai.

Độ trễ: t_0 lúc gửi request, t_1 lúc alert có trên API hoặc SSE, $p95$ của hiệu trên luồng L, ngưỡng dưới 5 giây. Nhịp 20 dòng mỗi giây trong 500 giây. Nếu $p95$ vượt ngưỡng ở nhịp này thì dừng, chưa tăng nhịp.

Coverage luồng L: trên khoảng 2 000 dòng tấn công đã biết category, đếm dòng có ít nhất một hit đúng category, tính riêng SQLi, XSS và PT. FPR bằng số dòng benign bị alert chia cho khoảng 8 000.

Ngoài lần thử: không so CRS, không bật Ollama, không sửa weight, không hạ K từ 3 xuống 2 sau khi nhìn số.

6.3 Kết quả mong đợi

Đã đo, làm mốc trước replay. 14/14 rule pass, precision từng rule bằng 1, FPR trên benign `HttpParams` bằng 0, dưới công 2%. Coverage held-out: PT 48,00%, SQLi 50,52%, XSS 68,12%. Trên adversarial, lệch tương ứng +3,36, −0,94 và +1,73 điểm. Tập adversarial SQLi lớn gấp khoảng 5 lần held-out. Trong miền chuỗi tĩnh, chưa có bước nhảy ± 15 điểm.

Kỳ vọng trên 120 request nếu severity khớp bảng. 18 alert, 18 incident baseline, 5 incident đề xuất, giảm 72,2%. CRITICAL bỏ sót bằng 0. 102 request sạch không sinh alert. Nếu sinh, FPR của riêng kịch bản này khác 0 và rule gây hit được liệt kê trước khi kết luận H1.

Nếu coverage SQLi rơi dưới 35,52% trong khi offline vẫn 50,52%, tách nguyên nhân trước khi sửa rule: bọ query làm hỏng pattern, Nginx encoding khác CSV, hoặc cửa sổ thời gian. Hai nguyên nhân đầu thuộc RQ1. Cửa sổ 5 phút thuộc RQ2 và `freq_bonus`, không dùng để giải thích coverage từng payload.

Bảng 10: Ngưỡng đạt trên luồng 10 000 dòng.

Hạng mục	Đạt khi	Mốc
Coverage SQLI	$\geq 35,52\%$	50,52 – 15
Coverage XSS	$\geq 53,12\%$	68,12 – 15
Coverage PT	$\geq 33,00\%$	48,00 – 15
FPR benign	$\leq 2\%$	Cổng evaluator; mốc norm hiện là 0%
Incident	Giảm $\geq 15\%$, CRITICAL bỏ sót = 0	Baseline một-một trên cùng luồng
Độ trễ	$p95 < 5$ giây	Tại ≥ 20 sự kiện/giây

Nếu mức giảm incident trên luồng L dưới 15% trong khi kịch bản 120 dòng vẫn ra 5 so với 18, policy đúng trên burst cùng IP và không đủ khi IP phân tán. Kết luận khi ấy: H1 có điều kiện về độ lặp (`app_id`, `client_ip`). Đó là kết quả hợp lệ của nghiên cứu thử.

Ba câu không đưa vào kết quả lần thử, dù slide có chỗ trống: tốt hơn WAFBooster 15%, tốt hơn GenXSS, accuracy vượt SVM trên CSIC. Ba câu ấy dùng chỉ số và kênh nhìn khác bảng 10.

7. Kết luận

Dàn ý tuần 3 chốt ba câu hỏi. RQ1 hỏi coverage trên log có mốc thời gian có lệch quá 15 điểm so với 50,52%, 68,12% và 48,00% hay không. RQ2 hỏi số incident có giảm ít nhất 15% so với một alert một incident hay không, với ràng buộc không bỏ sót CRITICAL. RQ3 hỏi $p95$ có dưới 5 giây trên ít nhất 10 000 dòng ở nhịp 20 sự kiện mỗi giây hay không.

Phương pháp là thực nghiệm đối chứng trên cùng 14 rule, hai chính sách incident và hai quy mô. Dữ liệu offline đã có: HttpParams 31 067 giá trị, held-out 7 002, adversarial 34 770, 14 rule precision 1 và FPR 0. Phần còn phải sinh là probe có nhãn và replay JSON có timestamp.

Cách đưa bài báo sang realtime là giữ bước cụm rồi thành rule và giữ cổng FPR, bỏ RNN cùng GPT khỏi consumer, bọc CSV thành access log, rồi tách alert, incident và SSE. Mức +75 điểm của WAFBooster và khoảng 86% của GenXSS đứng ở thí nghiệm và chữ ký. Coverage nội bộ trên tập adversarial lớn hơn khoảng năm lần chỉ lệch dưới 4 điểm. Mốc 15% của đề án vì thế gắn vào số incident và vào sản coverage.

Nghiên cứu thử tính sẵn một burst 120 request: 18 alert thành 5 incident, giảm 72,2% nếu severity đúng, rồi mới đo 10 000 dòng. Replay chạy trước khi promote đúng K và W sẽ cho số incident không dùng được cho RQ2.

Tài liệu

- [1] HTTP dataset CSIC 2010. Viện An ninh Thông tin, CSIC, Tây Ban Nha, 2010. Khoảng 36 000 request thường và 25 000 request bất thường, không có timestamp cho correlation theo cửa sổ phút.
- [2] Morzeux. HttpParamsDataset, 2015–2016. 19 304 giá trị tham số benign và 11 763 giá trị bất thường, rút từ CSIC, sqlmap, xssya, Vega và FuzzDB.
- [3] Wu và cộng sự. WAFBooster: Automatic Boosting of WAF Security Against Mutated Malicious Payloads. arXiv:2501.14008, 2025. True rejection 21% lên 96% trên 8 WAF, không false rejection trong báo cáo của bài.
- [4] Babaey và Ravindran. GenXSS: an AI-Driven Framework for Automated Discovery of XSS Attacks. arXiv:2504.08176, 2025. Khoảng 15 rule ModSecurity chặn khoảng 86% payload XSS từng bypass.
- [5] Nhóm G21. Solution design v1.6 và báo cáo tuần 2. Tham số $K=3$, $W=5$ phút, ngưỡng 60, và bảng đối chiếu bốn nhóm nghiên cứu liên quan.